

[AI翻訳チャット+通話アプリ] フロントエンド品質・セキュリティ監査書

Step3 詳細設計前のセキュリティ監査・堅牢性レビュー

1. 監査目的

画面実装（HTML/CSS/JS）フェーズへ移行する前に、フロントエンド側で発生しうる致命的なセキュリティホール、UIロジックのバグ、および極端なユーザー入力による表示崩れのリスクを事前に洗い出し、堅牢な設計を確定させる。

2. 監査・検証項目結果

① 画面表示の安全性（XSS対策）

- ・**リスク**：チャット入力欄に悪意あるJavaScriptコード（<script>等）が入力された際、そのまま画面にレンダリングされて実行されてしまうリスク。
- ・**対策方針**：ユーザーの入力値をチャットの吹き出しとして画面に追加する際、絶対に `innerHTML` を使用せず、`textContent` もしくは `innerText` を使用してプレーンテキストとして安全に処理する。

② 特殊文字・長文によるUI崩壊防止

- ・**リスク**：スペースのない100文字以上の英単語、極端に長いURL、絵文字の大量入力によって、吹き出しが画面外に突き抜けてレイアウトが崩壊するリスク。
- ・**対策方針**：チャットの吹き出しコンテナ要素に対して、Tailwind CSSの `break-all`（または `break-words`）および `overflow-wrap: break-word` を明示的に指定し、最大幅（`max-w-[70%]` 等）を設定する。

③ 入力バリデーション（空文字・連打バグ防止）

- ・**リスク**：空白のメッセージやスペースだけの入力で送信ボタンが連打され、無駄な吹き出しが画面を埋め尽くすバグ。
- ・**対策方針**：JavaScript側で送信処理が走る直前に `chatInput.value.trim()` を実行し、値が空文字列の場合は処理を `return`（中断）させる。送信完了後は即座にをクリアする。

④ モックアップ挙動の整合性

- ・**リスク**：見た目だけの通話画面に切り替わった後、ユーザーが混乱したり、元のチャットに戻れなくなったりするUI設計の不備。
- ・**対策方針**：通話中は視覚的に「📞 通話中…」という状態と時間のカウントアップを大きく明示し、最も押しやすい位置に赤色の通話終了ボタン（`hangup-btn`）を配置して迷わせない設計にする。

⑤ エラー時の画面保護とユーザー誘導

- ・**リスク**：将来的なAI翻訳通信エラー時に、画面全体がフリーズしたり白飛びしたりするリスク。

- **対策方針：** エラー発生時もUI全体の動作は維持し、エラーとなったメッセージの真下に赤字で「⚠ 翻訳に失敗しました。」という警告UIと、再試行ボタンを局所的に表示させる。

3. 監査判定

判定：良好（承認）

提示された対策方針を実装要件に組み込むことで、フロントエンド単体での堅牢性と品質が担保されることを確認。重大な脆弱性・表示バグのリスクはクリアされたと判断し、Step4（詳細設計書への反映）への移行を承認する。